《软件安全》课程大作业

项目定位：每组选择一个题目，在已有理论知识和三次实验基础上，完成一个能运行、可测试、有改进或明确风险处置结果的小型软件安全项目。允许复用教师提供的环境和基础工具，但不能只重复课堂实验、仅修改参数或堆积运行截图。

C 语言程序安全 · 6 题	Web 应用安全 · 10 题	AI 软件安全 · 10 题

建议工作量：1—5 人/组，3–4 周完成；Web 项目以 PHPStudy 本地环境为主，AI 项目优先使用 Windows、CPU 和 Jupyter，无需 GPU。

一、C 语言程序安全（6 题）

围绕已经学习的缓冲区边界、格式化输出、程序运行与动态调试，完成小型程序的输入检查、问题定位与修复复测。

C01 文本处理程序的安全设计与测试

项目内容：开发一个读取文本、按关键词查找和输出摘要的 C 语言程序，围绕文件输入到字符串处理的完整路径开展安全检查。

具体任务：

（1）实现文件读取、关键词查找和结果输出，明确最大文件长度、输入缓冲区与返回值处理规则。

（2）检查文本长度、末尾终止符、空文件以及读取失败等情况；在本地可复现的测试输入下定位至少一处需要改进的边界处理逻辑。

（3）增加长度检查、错误提示和必要的安全输出方式，保证程序对异常输入有明确响应。

（4）整理正常、临界长度、超长、空文件和特殊字符等输入，比较改进前后的结果。

完成要求：至少完成 3 项基本功能、10 组有效测试；交付可编译 C 源码、输入样本、修改前后代码说明及复测记录。

C02 命令行工具的输入安全改进

项目内容：开发一个支持文件操作与数值参数的本地命令行小工具，检查参数处理和错误分支对程序稳定性的影响。

具体任务：

（1）实现文件路径、操作类型和数值选项的解析，至少支持两种业务操作。

（2）设计缺失参数、非法数字、超出范围的数值、过长路径和不存在文件等情况；通过日志或调试器观察处理分支。

（3）补充参数类型、数值范围和文件打开结果检查，消除未经验证数据直接参与索引或缓冲区操作的情形。

（4）编写可重复运行的输入清单或简单测试脚本，验证异常情况被安全拒绝，正常功能保持不变。

完成要求：至少 2 种操作、12 条测试用例；交付 C 源码、运行说明、异常情况对照表和完整的复测结果。

C03 学生信息管理程序的内存安全检查

项目内容：围绕学生姓名、学号和成绩等模拟信息，实现本地记录管理程序，并评价数组、索引与字段长度的安全处理。

具体任务：

（1）实现记录新增、按学号查询、修改和保存，数据仅使用模拟学生信息。

（2）分析数组容量、学号查找结果、字符串字段长度、文件末尾与不完整记录，明确可能造成越界或错误写入的位置。

（3）补全容量检查、字段长度限制和非法索引处理，并验证修改后仍能正确新增、查找与保存。

（4）针对记录数临界值、重复学号、空字段、超长姓名及损坏文件进行系统测试。

完成要求：至少 4 项业务操作、12 条测试；提交 C 源码、模拟数据、问题定位说明与改进前后对照。

C04 日志输出程序的安全改造

项目内容：开发可接收文件消息和用户输入的本地日志工具，分析外部文本进入格式化输出函数时的处理方式。

具体任务：

（1）实现两种消息来源、日志级别和日志保存或终端输出功能。

（2）对比固定格式字符串和外部数据直接充当格式说明的调用方式，使用无害格式符号和长文本检查输出行为。

（3）将外部文本明确作为数据处理，补充长度限制、错误返回检查和统一的日志输出接口。

（4）设计正常文本、空字符串、特殊字符、长消息和文件读取失败等场景，比较改进前后记录是否准确。

完成要求：至少 2 种输入来源、10 条测试；交付 C 源码、日志样本、关键调用对照和修复验证材料。

C05 文件解析程序的异常分析

项目内容：编写用于读取简单 CSV 或键值文本的小型解析器，围绕错误输入引起的异常进行定位、修复与复测。

具体任务：

（1）实现按行读取、字段拆分、数值转换与结果输出，明确允许的文件格式。

（2）构造缺字段、多分隔符、超长字段、非法数值和不完整记录等测试输入，定位不同错误出现的位置。

（3）使用源码调试或运行日志记录关键变量及错误路径；必要时结合可用的内存检查工具。

（4）完善字段边界和异常处理，并将全部输入重新运行以确认修复效果。

完成要求：至少 3 项解析功能、12 个样本，其中不少于 5 个异常样本；提交解析器源码、测试数据与定位复测表。

C06 动态内存管理程序的安全测试

项目内容：开发一个使用动态内存的本地任务列表或队列程序，分析内存申请、释放和异常分支中的安全性与健壮性。

具体任务：

（1）实现记录创建、追加、删除和查询，动态分配与释放所需存储空间。

（2）检查申请失败、容量扩展、重复删除、空列表与退出清理等情形，画出关键对象的生命周期。

（3）补充指针状态维护、申请结果检查和集中释放逻辑，避免重复释放、泄漏或无效访问。

（4）通过循环添加/删除、空列表操作和异常容量等用例完成测试，必要时借助调试器观察内存状态。

完成要求：至少 4 项功能、10 条用例；提交 C 源码、内存生命周期说明、错误处理与前后复测记录。

二、Web 应用安全（10 题）

围绕 HTML 表单、HTTP 请求、PHP、数据库查询、会话、文件处理和服务端校验，开发或完善本地小型 Web 应用并验证安全处理。

W01 校园公告系统的安全评测

项目内容：开发可查询、发布和管理公告的本地 PHP 系统，围绕页面输入、数据库查询与结果显示开展安全评估。

具体任务：

（1）实现公告列表、编号查询、关键词检索和发布/编辑等至少三项业务操作，并提供 SQL 建表及测试数据。

（2）梳理 GET/POST 参数进入 PHP、SQL 和 HTML 输出的路径，检查非法编号、条件拼接及显示特殊字符的情况。

（3）对查询使用服务端校验与参数化 SQL，对不可信文本采用与输出场景相匹配的编码或安全 DOM 输出。

（4）以正常编号、缺失编号、无记录、异常表达式和特殊字符等用例完成前后对照。

完成要求：至少 3 项功能、12 条请求测试；交付 PHP/SQL 源码、数据文件、风险分析与改进后复测表。

W02 用户登录系统的安全实现

项目内容：构建本地注册、登录、退出和角色访问的 PHP 小应用，检查身份认证与授权控制在服务端的实现。

具体任务：

（1）完成注册、登录、退出、个人页面访问，设置普通用户与管理员两类角色。

（2）对账号和口令进行合理校验，口令采用安全哈希保存，数据库操作使用参数化查询。

（3）使用 Session 维持登录状态，并在每个受限功能入口检查身份与权限，而非只隐藏前端按钮。

（4）测试错误口令、重复注册、未登录访问、普通用户访问管理页面和退出后重新访问等情况。

完成要求：至少 4 项功能、2 种角色和 12 项访问测试；提供源码、数据库、权限矩阵和服务器端拦截证据。

W03 课程资料共享平台的安全设计

项目内容：开发课程资料上传、展示与下载功能，针对文件类型、大小、保存位置与下载权限进行系统设计。

具体任务：

（1）实现文件上传、资料列表、查询和下载；限定允许的文件类型和大小，使用不含敏感信息的课程模拟资料。

（2）检查扩展名、真实内容类型、上传错误码、文件大小及文件名处理，避免仅凭后缀判断文件。

（3）采用非可执行区域或隔离目录存储、随机命名与下载路径/编号校验；增加必要的访问权限。

（4）用正常文件、改名文件、超限文件、非法编号和未授权下载请求开展前后复测。

完成要求：至少 3 项业务操作、10 个文件/请求测试；交付源码、合规示例文件、权限说明及对照结果。

W04 在线留言系统的安全改进

项目内容：设计留言发布、查询和管理页面，研究用户文本在数据库与浏览器页面之间流转时的安全处理。

具体任务：

（1）实现留言提交、列表显示、分页或关键词查询，以及管理删除/审核等一个辅助功能。

（2）区分服务端输入校验、数据库参数绑定与 HTML 输出编码的作用，定位文本处理位置。

（3）修正不可信文本直接拼接到输出环境的问题，对前端 DOM 更新选择合适的安全接口。

（4）设计普通汉字、引号、标签样式文本、长文本和空输入等无害样本，对比页面显示及数据库记录。

完成要求：至少 3 项功能、12 组测试；交付 PHP/SQL、关键请求与响应、修改前后页面和复测说明。

W05 个人资料网站的权限检查

项目内容：建立用户资料查看和修改的小型 Web 应用，重点检查会话状态、对象归属与服务端授权。

具体任务：

（1）实现登录、个人资料查看、资料修改与退出功能，并准备至少两位模拟用户。

（2）说明 Cookie 和 Session 的作用，梳理请求中的用户身份、目标资料编号和服务端权限判断。

（3）在服务器端校验当前用户与被访问记录的归属关系，修改操作加入必要的请求校验。

（4）比较正常访问、未登录访问、错误标识以及访问其他用户资料等本地测试情形。

完成要求：至少 4 项功能、2 个用户角色/账号和 10 条访问用例；提供源码、权限矩阵、日志与修复复测。

W06 图书检索系统的安全设计

项目内容：实现本地图书信息检索和借阅模拟流程，评估不同查询条件与用户输入对数据库处理的影响。

具体任务：

（1）创建图书数据表及借阅记录，支持图书编号/关键词查询、借阅操作和借阅结果展示。

（2）分析 URL/表单字段到 SQL 查询的参数处理，区分无记录、输入非法与数据库操作失败。

（3）完成输入类型校验、参数化查询和借阅数量或状态的服务端检查。

（4）使用正常查询、异常表达式、重复借阅、无效编号和借阅状态边界等场景进行系统验证。

完成要求：至少 3 项业务功能、12 条测试；提交 PHP/SQL、模拟数据、服务端检查代码和结果记录。

W07 课程报名系统的安全开发

项目内容：开发可浏览活动、提交报名和查看个人报名状态的本地课程报名系统，检查业务数据和访问权限。

具体任务：

（1）实现活动列表、报名/取消、个人报名记录与名额显示等功能，准备模拟用户和课程数据。

（2）检查报名编号、活动状态、重复提交与剩余名额等服务端逻辑，防止仅依赖前端限制。

（3）对数据库操作使用参数化查询，并对登录状态与用户记录归属进行验证。

（4）覆盖名额边界、重复报名、取消不存在报名、未登录操作等场景，比较改进前后的处理结果。

完成要求：至少 4 项功能、12 条测试；交付完整本地项目、SQL 表、测试用例、服务端修复与复测结果。

W08 失物招领网站的安全评测

项目内容：设计失物信息发布、图片提交和联系方式查看功能，完成输入、上传与用户访问的综合安全检查。

具体任务：

（1）实现信息发布、列表检索、图片上传与本人信息修改，使用模拟失物和虚构联系方式。

（2）检查文本输出、图片真实类型/大小、记录归属及上传目录的安全性。

（3）补齐服务端文件校验、输出编码、资料访问控制和安全错误提示。

（4）设计正常发布、改名图片、超限图片、非法记录编号、未登录编辑等本地测试，比较修复前后效果。

完成要求：至少 4 项功能、12 组测试；交付 PHP/SQL、允许的图片样本、权限检查与复测证据。

W09 Web 请求安全测试工具

项目内容：编写用于本地教学网站的自动化请求测试脚本，统一执行输入校验与数据库查询的正常和异常测试。

具体任务：

（1）选定本地公告/资料查询系统，定义请求地址、参数、预期状态与响应检查规则。

（2）实现测试用例读取、HTTP 请求发送、响应判定和 CSV/HTML 结果汇总。

（3）覆盖合法输入、缺失字段、非法格式、超长值和不存在记录；记录失败请求及其对应服务端处理位置。

（4）选取至少两类未达预期的情况进行原因定位或规则改进，并再次运行完整测试集。

完成要求：至少 15 条自动执行用例、2 类输入场景；提交测试代码、配置、报告和复测记录。

W10 PHP 网站的安全回归测试

项目内容：选择课程提供或自建的小型 PHP 应用，为其中两个业务模块建立修改前后都能使用的回归测试体系。

具体任务：

（1）明确两个模块的正常功能、关键输入字段和可观察输出，例如公告查询与资料上传。

（2）针对每个模块设计正常、边界和异常用例，自动记录请求、响应和通过/失败情况。

（3）完成至少两处可解释的服务端改进（如参数校验、参数绑定、上传内容检查或访问控制）。

（4）使用同一测试集对修改前后版本执行复测，解释被拒绝输入和正常功能是否保持正确。

完成要求：至少 2 个业务模块、15 条自动测试；提供版本对照、修改代码、测试脚本及可重复运行的结果报告。

三、AI 软件安全（10 题）

围绕已经讲授的分类模型、输入梯度、FGSM、PGD、扰动预算和效果评价，开展低配置 CPU 环境下的模型评估、工具开发与软件安全分析。

A01 手写数字识别系统的安全评估

项目内容：以本地 CPU 手写数字分类模型为对象，将单样本 FGSM/PGD 测试扩展为多样本的安全评测项目。

具体任务：

（1）统一模型、数据划分、像素范围和正常预测基线，自动筛选干净预测正确的样本。

（2）对同一批样本运行 FGSM 与 PGD，设置不少于三档扰动预算，记录攻击后预测与实际 L_∞。

（3）按明确统计口径计算攻击成功率、攻击后准确率与耗时；保留失败与未改变类别的样本。

（4）分析预算和攻击方法与结果的关系，并实现结果导出和典型样本图像对照。

完成要求：至少 40 个干净正确样本、2 种方法、3 档预算；交付可运行 Notebook、CSV 结果及不少于 2 幅分析图。

A02 图像分类安全测试平台

项目内容：开发可输入测试配置、批量运行与导出结果的小型本地评测程序，重点体现可重复的测试流程。

具体任务：

（1）实现样本选择、攻击方法选择、预算/迭代次数配置与随机种子设置。

（2）封装正常预测、攻击输入生成和成功条件判断，避免仅在 Notebook 中手工重复运行多个单元。

（3）自动生成记录表，包含样本编号、目标类别、预测、实际扰动、参数和运行耗时。

（4）对固定配置重复运行，检查结果的一致性并提供失败样本的查看方式。

完成要求：支持 FGSM 和 PGD、3 档预算、至少 40 个样本；提供本地运行入口、CSV 输出、操作说明及 2 种可视化。

A03 图像模型的版本安全比较

项目内容：使用相同数据分别训练两份轻量级 CPU 分类模型，对比模型更新前后的正常性能与受扰动表现。

具体任务：

（1）设置两个明确不同的版本，如随机种子、隐层规模或训练参数，并保存各版本的参数配置。

（2）固定训练/测试划分，比较两版模型的正常准确率和错误样本。

（3）分别针对每一模型生成 FGSM/PGD 输入，在同一预算条件下比较攻击结果，避免将跨模型输入误当白盒攻击。

（4）分析模型性能提升是否伴随受扰动表现变化，输出版本差异和回归结论。

完成要求：2 个模型版本、至少 30 个测试样本、2 种攻击；提交训练与评测代码、模型配置及比较图表。

A04 图像预处理的安全测试

项目内容：在本地图像分类程序中加入不同预处理分支，分析图像数值处理对正常识别和受扰动识别的影响。

具体任务：

（1）实现并说明至少两种预处理方式，如像素量化、轻度平滑或合理的输入范围裁剪。

（2）记录各分支处理前后的像素差异、输入范围和正常预测变化。

（3）在明确的攻击预算与相同评价集上比较处理前后的受扰动结果，并检查实际输入变化。

（4）分析正常准确率与异常输入处理的权衡，不以个别样本恢复正确宣称全面防御。

完成要求：至少 2 种预处理、30 个样本、3 档参数；交付可运行代码、前后对照图与适用范围说明。

A05 视觉识别风险提示系统

项目内容：为本地图像识别服务增加概率展示和低置信度提示，形成“预测—提示—人工复核记录”的业务流程。

具体任务：

（1）实现输入图片、显示分类结果及各类别分数的界面或 Notebook 交互。

（2）设置可调阈值，当最大分类分数低于阈值时给出提示并记录复核状态。

（3）使用正常、轻度变化及对抗候选输入对照不同阈值的提示数量和漏提示情况。

（4）实现日志导出与误提示/漏提示统计，明确分类分数未必是经过校准的正确概率。

完成要求：至少 40 个输入样本、3 档阈值、日志和结果表；展示可运行原型并说明提示规则的局限。

A06 目标攻击分析工具

项目内容：围绕预先指定类别的图像分类任务，实现目标攻击、结果核验和可视化，重点明确目标攻击与非目标攻击的差别。

具体任务：

（1）在同一分类模型下支持非目标攻击和目标 PGD 两种模式，要求目标标签在运行前选定。

（2）分别实现真实标签损失上升和目标类别损失下降的更新逻辑，统一像素裁剪与预算约束。

（3）记录真实标签、指定目标、最终预测、实际扰动及目标是否命中。

（4）比较不同目标类别或预算下的结果，分析目标未命中但发生错分的情况。

完成要求：至少 2 个目标类别、30 个原本正确样本、2 档预算；交付代码、目标命中统计和典型样本对照。

A07 对抗测试结果管理系统

项目内容：开发用于保存、筛选和展示对抗测试结果的本地分析工具，使每一次实验具有可追踪的模型和参数信息。

具体任务：

（1）定义记录字段，包括模型版本、样本、标签、攻击类型、预算、迭代次数、预测结果与耗时。

（2）实现批量导入或自动生成测试记录，并支持按攻击方法、成功状态和预算筛选。

（3）生成预算与 ASR 变化图、典型扰动对照及失败样本统计，必要时提供 CSV/HTML 导出。

（4）加入记录完整性检查，识别缺少标签、参数不一致或统计分母错误等问题。

完成要求：至少 50 条实验记录、3 项查询/展示功能、2 种图表；交付分析工具、演示数据及可复现实例。

A08 模型推理接口的安全检查

项目内容：为本地 CPU 分类模型设计简单的输入接口，并检查不规范输入、异常形状和错误类型的处理方式。

具体任务：

（1）封装图片输入、预处理、预测和结果返回流程，可采用 Python 函数、简单界面或本地 HTTP 接口。

（2）定义允许的图像尺寸、数据类型、像素数值范围和请求大小，并实现明确的错误提示。

（3）构造正常图像、空输入、非法形状、NaN/越界数值及重复请求等情况进行测试。

（4）加入测试日志与输入检查，并对比改进前后的处理结果及正常预测是否保持。

完成要求：至少 3 项接口/校验功能、12 条测试；交付 CPU 可运行程序、测试输入、异常记录及复测说明。

A09 AI 生成 Web 代码的安全检查

项目内容：针对一个相同的本地 PHP 业务需求，分析 AI 生成代码与人工改进代码在功能正确性和输入安全方面的差异。

具体任务：

（1）明确一个简短完整的业务需求，如公告查询或用户信息提交，并保存 AI 生成时的提示和原始结果。

（2）按同一需求建立功能测试和异常输入测试，检查 SQL 访问、参数验证、错误处理和页面输出。

（3）对发现的问题给出可验证的原因分析并完成安全修改，不仅依赖 AI 给出的文字解释。

（4）在相同测试集上比较原始版本与改进版本的正常功能、异常输入处理和测试通过情况。

完成要求：一个小型 Web 业务、至少 12 条测试、2 处可解释改进；交付两版代码、提示记录和结果对照。

A10 AI 生成 C 程序的安全比较

项目内容：针对同一份 C 语言文本处理或文件解析需求，比较 AI 生成的初版程序与经人工审查的改进程序。

具体任务：

（1）编写包含输入范围、文件格式和异常处理要求的任务说明，并保留生成代码与提示。

（2）检查字符数组、输入长度、转换结果和文件操作返回值等关键位置。

（3）建立统一的正常、临界、无效和超长输入集合，定位至少两处需要修改的安全问题或健壮性不足。

（4）修改程序并重新运行同一批测试，分析哪些问题被解决、是否影响原有功能。

完成要求：至少 2 版 C 代码、12 条测试、2 处代码改进；交付编译运行说明、测试脚本/记录与对照报告。

四、统一任务与提交要求

选题与组队：每组 1—5 人，任选一个题目。可提出难度相近的自拟题目，经教师确认后实施。每个题目应明确负责人、模块分工和测试分工。

基本工作：至少包含一个可运行程序/功能模块、可说明的安全问题或风险假设、一套有效测试用例、改进或风险处置措施，以及改进前后对照或同条件评价。课程基础代码可复用，但必须有实质性新增工作。

项目报告：建议正文 10—15 页，依次说明项目目的与范围、系统或模型结构、个人与小组分工、实现方法、测试环境、关键证据、问题分析、修改或处置措施、复测结果、结论与局限。图表必须注明参数、数据与统计口径。

运行材料：提交完整源码或 Notebook、必要的 SQL/配置文件、模拟测试数据、运行说明 README 及关键结果记录。教师应可在所述本地环境中重现主要功能与结论。

汇报材料：提交汇报 PPT（建议 8—12 页）和成员贡献说明；如使用 AI 辅助生成代码或报告，注明使用范围、引用来源和人工验证方式。

安全边界：仅对本地自建、课程提供或明确获得授权的对象测试；不对真实公网服务开展未经授权测试，不使用真实用户口令或敏感信息，不部署具有危害性的样本。失败结果和限制条件须如实记录。

五、统一汇报答辩与考核方式

汇报：建议每组 8–10 分钟项目介绍与关键功能演示，3–5 分钟现场问答。重点讲清“做了什么—为什么需要—如何实现—如何测试—发现了什么—怎样改进—复测结果”。教师可随机请成员说明自己负责的代码、测试和结论。(线上另寻时间)

课程总评：平时成绩 20% + 实验一 10% + 实验二 10% + 实验三 10% + 课程大作业 50%。大作业先按 100 分计分，再以 50%权重计入总评。

大作业评分建议（100 分）：项目设计与自主实现 30 分；测试设计与结果证据 25 分；问题分析与改进复测 20 分；报告及运行材料 10 分；现场汇报答辩 10 分；个人贡献与安全规范 5 分。